Strengthening Information Security in Small to Medium-Sized Enterprises (SMEs): A Practical Approach to Risk, Recovery, and Workforce Awareness

Assignment 1

ICT280 Information Security Policy and Governance

Rohit kumar Malik

Contents

1. Introduction 2
2. Justifying the Need for sound Information Security management in SMEs 2
3. Incident Response and Disaster Recovery 4
4. Security Training and Education 5
5. Conclusion 7
6. Reference 8

Submitted by: Rohit Kumar Malik
Student ID: 35363998
Unit: ICT280 - Information Security Policy and Governance
Lecturer: Mr. Salih lsmail
Submission Date: June 22, 2025

1. Introduction

In today's information age, **information security** is vital to all types of organisations, not just large business corporations. In comparison to larger organisations, small and medium enterprises (SMEs) are now becoming the prime target of cyber criminals because of their limited assets and resources, as well as weaker security interests in cybersecurity. Although multinational corporations may make the news when they get hacked, it is often SMEs that bear the brunt of these breaches, having to undergo significant reputational damage without being able to afford complex recovery measures.

Despite this new threat, information security remains **secondary** to most SMEs. Unlike big corporations that can afford hiring security experts and complex models, SMEs usually lack even the most basic forms of protective measures, which places these businesses at heightened risk for data theft and loss, ultimately shutting down operational workflows as well as facing severe penalties for compliance violations.

This essay highlights the need to develop an effective information security policy for SMEs, especially in comparison to what others do in large corporations. This essay will present three points of relevance: first, **the overall justification for why SMEs need to take information security seriously**; second, **the role of incident response and disaster recovery planning in ensuring business continuity**; and third**, how employee training and awareness can play a crucial role in reducing risk.**

By looking into such industries, the purpose of this essay is to provide insightful suggestions regarding how SMEs can practically enhance information security concerns practically and at a fair cost.

2. Justifying the Need for sound Information Security management in SMEs

Small and medium-sized businesses (SMEs) form the backbone of every economy, they play an important role with respect to employment, innovation, and GDP value. But in their growing dependency on digital infrastructure, they have also been left vulnerable to the same cyber threats that beset larger organisations, often with far fewer resources to defend themselves. Unlike multinational corporations, SMEs often have no **IT departments**, no formal **risk analysis**, or incident response plans. This reality makes it even more necessary to

explain and place greater importance on having an organised approach to information security in the context of SMEs.

One of the biggest reasons why SMEs need reliable information security is that there is a higher sophistication and volume of cyberattacks. The most recent statistics reveal that a staggering proportion of all cyberattacks today are aimed at small businesses (Verizon, 2023; IBM Security, 2022), primarily because they are viewed by hackers as "soft targets" that lack stronger security measures (ENISA, 2021). Some common attacks that can shut down operations or cause irretrievable loss of data are **phishing** emails, **ransomware**, and business email compromise. In many cases, reported breaches have forced SMEs to undergo temporary shutdowns or never fully recover.

Apart from technical risks, legal and regulatory aspects are in question. Most SMEs process sensitive data like personal data, financial reports, or health records, which makes them liable to adhere to **data protection** laws like **GDPR** or their equivalents. Non-compliance, even unintentional, can lead to substantial penalties and loss of reputation. Compared to large companies, which may withstand such a hit, SMEs are more vulnerable to economic shocks and therefore, active information security is not only a technical concern but a crucial business strategy.

There is mounting customer and client sensitivity to data privacy as well. Companies are now being evaluated based on how they handle such information. An SME that fails to protect sensitive user **information stands** to lose customer’s trust, harm its reputation, and be unable to acquire new customers. Conversely, showing concern for best practice in security through policy, certification, or open communication can be a market draw, particularly for fields such as finance, health, or law.

The absence of funds is typically cited as a reason for not investing in **cybersecurity** by SMEs, yet information security controls do not always require funds. Strong authentication policies, patched software, and some security awareness training can mitigate risk significantly (ACSC, 2023; NIST, 2021). In addition, free frameworks like NIST or ISO (NIST, 2021) offer flexible standards even for small-sized businesses to scale to their size and intricacy.

One of the benefits of demonstrating the need for **InfoSec** is in breaking away from the assumption that security is a technical issue. Information security touches every corner of an organisation, from HR processes and staff training to vendor management and strategic planning. This perspective helps embrace cybersecurity as an enabler of business growth, opening new possibilities to **SME leadership**. **For example**, a small organisation with a properly secured system is more likely to get contracts from large partners who insist on data protection assurance.

It's also important to compare SMEs with big companies, not to highlight their deficiencies but to identify where custom-fit solutions are necessary. Businesses may enjoy the advantage of employing sophisticated equipment and on-staff security experts, whereas SMEs may utilise managed security services, government initiatives, or **cloud security** with built-in protection. It isn't about imitating large organisations, but to develop a realistic and robust InfoSec posture that accommodates an SME's business and threat environment.

In summary, SME's information security is not something they have a choice about, but something they must have. With threats mounting and regulations getting tougher, SME's must adapt to survive and thrive in the digital economy. Providing rationale for the importance of InfoSec, thus, requires not only a technical understanding of threats but a broader appreciation of how it contributes to facilitating business continuity, trust, and competitiveness.

3. Incident Response and Disaster Recovery

For any organisation, the ability to respond to and recover from a **security breach** is a critical capability, but for small and medium-sized enterprises (SMEs), this capability can mean the difference between remaining alive and closing permanently. While larger businesses typically have documented incident response teams and formal **disaster recovery (DR)** plans, SMEs typically do not have these defences, relying on the hope that worst-case incidents are not likely or that recovery planning is too expensive or complex to implement. This hope places many SMEs at risk of being unprepared for events that have catastrophic consequences.

Disaster recovery (DR) and **Incident response (IR)** are two closely interconnected yet distinct components of a broader contingency planning approach. The focus of incident response is on actions taken immediately to contain an attack or failure and mitigate damages, while disaster recovery refers to restoring systems, data, and operations to normal after a disruption. Both are important, and neither can be neglected, particularly in the SME context where operations are more prone to disruption and any downtime is often unaffordable.

The evidence suggests that SMEs are increasingly victims of ransomware (Ponemon Institute, 2022), **phishing**, and denial-of-service attacks. Most of these attacks take advantage of unpatched software, poor access control, weak remote work security measures, and overall lax user controls. Lacking an incident response plan, SMEs must react in panic mode, facing extended downtimes, loss of data, and even regulatory compliance if customer data is involved. Large organisations, on the other hand, are often able to quickly detect and mitigate such incidents earlier since they have standard operating procedures, trained response teams, and simulation-tested procedures.

An incident response plan need not be **complex or costly**. It should instead outline essential duties and roles, communication, severity levels, and step-by-step response procedures for various types of incidents (Ejaz, Rahim, & Chohan, 2024). Even a small business can designate an employee to be responsible for coordinating the response, setting simple notification trees, and maintaining easy response checklists. In addition, tailored guidance aimed at SMEs has been published by **security organisations** as well as **government agencies**, making the adoption of practical frameworks far easier (ACSC, 2023).

Disaster recovery is also necessary, particularly with the growing use of **digital services**. Any critical system can be derailed by a single ransomware attack, power outage, or hardware failure. Whereas large organisations can switch over to backup servers or employ high-

availability hardware, SMEs do not have these failovers. This emphasises the importance of cloud storage solutions, off-site recovery procedures, and data backups. But data backup is not enough, recovery steps must also be periodically tested so that they are in working condition when needed.

Identification and prioritisation of risk is often neglected in DR planning for SMEs. All business functions are not so vital, and SMEs can gain a lot by using **business impact analysis (BIA)** to identify which systems must be recovered first in the event of a disaster (El-Hajj & Mirza, 2024). For example, customer billing may be more vital than internal reporting. **NIST SP 800-34** standards offer easy-to-implement approaches to describing essential operations and defining prospective RTO and RPO targets, both of which help to advise successful disaster planning (NIST, 2021).

It's also important to appreciate that not every incident is cyber-related. Fires, floods, equipment failures, or simple **human mistakes** may all cause significant downtimes. Planning for such incidents requires an integrated IT and business management framework that brings together the digital and physical worlds (ACSC, 2023). That's what allows the bigger firms to evolve seamlessly, and SMEs can similarly transform using simpler but better-organised policies.

Finally, **disaster recovery** and **incident management** are no longer a choice, even for tiny companies. With threats now being more common and costly, SMEs are compelled to embrace a shift from reactive to proactive positions. A well-designed IR and DR policy allows small companies to withstand unplanned events while safeguarding customer trust throughout periods of turmoil marked by unprecedented challenges.

4. Security Training and Education

When it comes to **information security, technology** is not the only factor to consider. Even the most secure systems can be reduced to ashes by one thoughtless employee click. This is especially true for small to medium-sized enterprises (SMEs), where most security violations are due to human error, not technical. While large organisations usually invest in structured training and awareness campaigns, SMEs tend to ignore or inadequately estimate education as a part of their security framework.

One of the key reasons SMEs are most vulnerable to attacks is inadequate **staff awareness** of basic security threats. Basic errors, such as opening attachments in suspicious emails, having weak passwords, or becoming a victim of social engineering attacks, remain prevalent. These are typically not due to negligence but to unintentional missteps arising from insufficient knowledge. With no initial training, even well-intentioned employees may end up being a liability in terms of cybersecurity. All studies uniformly show that phishing is still the number one attack vector, precisely because it exploits human judgment rather than technical vulnerabilities (Verizon, 2023).

Security Education, Training, and Awareness (SETA) initiatives seek to fill this void by teaching workers the habits and knowledge necessary to prevent such mistakes (Harlee & Jackson, 2024). For SMEs, rolling out a full-fledged SETA program may appear ambitious,

but even minimal training sessions, issued on a quarterly or semi-annual basis, can have a substantial impact on diminishing risk. Training doesn't have to cost a fortune either. Most decent organisations, such as NIST and cybersecurity centres, offer free or low-cost materials tailored for the small business environment (NIST, 2021; ACSC, 2023).

Unlike technology refreshes, which tend to require new budgets or vendor contracts, training leverages the existing assets of your staff. Training investment also contributes to developing a culture of security (Ponemon Institute, 2022), where employees begin to understand security as part of their standard work and not an IT function. It is especially important in SMEs, where functions overlap and employees handle many systems and information. When all members of staff understand their part in protecting information, the entire organisation is empowered.

A second critically significant feature of effective training is **customisation**. Large companies can use very formalised training programmes, but SMEs benefit more from scenario-based training designed around their specific threats and business processes. For instance, an SME in healthcare would cover the protection of patient data and an online consumer would cover payment fraud and the protection of customer communications. Incorporating the lessons into the day-to-day business activities makes it more relevant and memorable for employees (NIST, 2021).

Providing ongoing reinforcement is another essential element to consider. One-time sessions are not going to change long-term behaviour (Employee Cybersecurity Awareness Training, 2024). Instead, SMEs must implement constant interaction in the form of frequent email reminders, training tests, or mock phishing exercises. These continually refresh awareness without disrupting the working day and remind staff that security is a continuous process.

What sets high-performing organisations of any size apart is not that they don't face threats at all, but that they see them coming and respond to them early. Well-trained employees will be more likely to warn others about threats early, report correctly, and limit the spread of an attack. For SMEs that cannot adopt full-scale technical monitoring solutions, a **proactive response** like this can give an extra layer of security.

Compared to bigger companies, SMEs are inherently more limited. But this cannot be the excuse for ignoring training. SMEs also have the advantage of being agile less red tape means faster deployment of training programs, and faster reactions to changing threats. With honest communication and management backing, training can be one of the most effective and economical security tools smaller businesses can deploy.

Briefly, education and training are no longer afterthoughts in the threat landscape today. To SMEs, they constitute a key investment with direct implications on risk management, compliance, and organisational resilience. By arming staff with the right information, SMEs can lower their vulnerability to threats by a large percentage and develop a **security culture** from scratch.

5. Conclusion

In today's networked digital world, information security is not the concern of big corporations, it is only a necessity for small and medium-sized enterprises as well. This essay has discussed three main domains that lead us to an understanding of why SMEs must do their part in making their security stance stronger. On the other hand, disaster recovery planning and **incident response** have emerged as crucial for ensuring business continuity, but the majority of SMEs have no preparation or plan to recover from unforeseen disruptions. Thirdly, security training and education have been found to be a very effective, cost-efficient undertaking to reduce human error and establish a culture of awareness throughout all levels of the organisation.

It is not so much the size of their budget that distinguishes resilient SMEs from at-risk SMEs, but planning quality, attitude, and determination to continuous improvement. With frameworks increasingly easily accessible, complementary resources, and adaptable tools, even smaller-sized organisations can create a **solid, realistic information security plan**. By acknowledging that security is not a technical problem but a business requirement, SMEs set themselves up to succeed in a world where digital resilience and trust are the foundation of long-term success.

6. Reference

Australian Cyber Security Centre (ACSC). (2023). *Small Business Cyber Security Guide*. https://www.cyber.gov.au

El-Hajj, R., & Mirza, S. (2024). *A specialized cybersecurity risk assessment framework for SME resilience planning*. Electronics, 13(19), Article 3910. https://www.mdpi.com/2079-9292/13/19/3910

Ejaz, T., Rahim, M., & Chohan, K. (2024). *Developing a cybersecurity incident response framework for SMEs: Workforce roles and responsibilities*. International Journal of Cybersecurity Policy and Management, 6(1), 21–34. https://www.researchgate.net/publication/392283000_Developing_a_Cybersecurity_Incident_Response_Framework_for_SMEs_Workforce_Roles_and_Responsibilities

Employee Cybersecurity Awareness Training Programs Customized for SMEs. (2024). *Journal of Knowledge, Learning and Secure Technology*, 7(2), 85–99. https://jklst.org/index.php/home/article/view/276

European Union Agency for Cybersecurity (ENISA). (2021). *Threat Landscape 2021*. https://www.enisa.europa.eu/publications/enisa-threat-landscape-2021

Harlee, D., & Jackson, L. (2024, December). *Human error and cybersecurity in SMEs: Tailored training programs for a safer digital environment*. Cybersecurity Review Quarterly, 9(4), 55–68. https://www.researchgate.net/publication/386413640_Human_Error_and_Cybersecurity_in_SMEs_Tailored_Training_Programs_for_a_Safer_Digital_Environment

IBM Security. (2022). *Cost of a Data Breach Report*. https://www.ibm.com/reports/data-breach

National Institute of Standards and Technology. (2021). *Cybersecurity Framework*. https://www.nist.gov/cyberframework

Ponemon Institute. (2022). *Cybersecurity in Small and Medium-Sized Businesses: 2022 Survey Results*. https://www.ponemon.org/

Verizon. (2023). *Data Breach Investigations Report (DBIR)*. https://www.verizon.com/business/resources/reports/dbir/